LECTURE 5: E-COMMERCE SECURITY AND FRAUD PROTECTION

LEARNING OBJECTIVES

1. Understand the importance and scope of the security of information systems for EC.
2. Describe the major concepts and terminology of EC security.
3. Learn about the major EC security threats, vulnerabilities, and risks.
4. Understand phishing and its relationship to financial crimes.
5. Describe the information assurance security principles.

LEARNING OBJECTIVES

6. Identify and assess major technologies and methods for securing EC communications.
7. Describe the major technologies for protection of EC networks.
8. Describe various types of controls and special defense mechanisms.
9. Describe the role of business continuity and disaster recovery planning.
10. Discuss EC security enterprise-wide implementation issues.
11. Understand why it is not possible to stop computer crimes.

CYBERWAR:
MUTUALLY ASSURED DESTRUCTION 2.0
CLASS DISCUSSION

- What is the difference between hacking and cyberwar?
- Why has cyberwar become more potentially devastating in the past decade?
- What percentage of computers have been compromised by stealth malware programs?
- Will a political solution to MAD 2.0 be effective enough?

WHAT IS E-COMMERCE SECURITY

- **WHAT IS E-COMMERCE SECURITY**
  - is the protection of e-commerce assets from unauthorized access, use, alteration, or destruction.
  - *Computer security* refers to the protection of data, networks, computer programs, computer power, and other elements of computerized information systems

WHAT IS E- COMMERCE ASSETS

E-Commerce Assets

- **Intellectual property**
- **Client computers**

  → push for point-and-click commerce
- **Messages traveling on the communication channel**

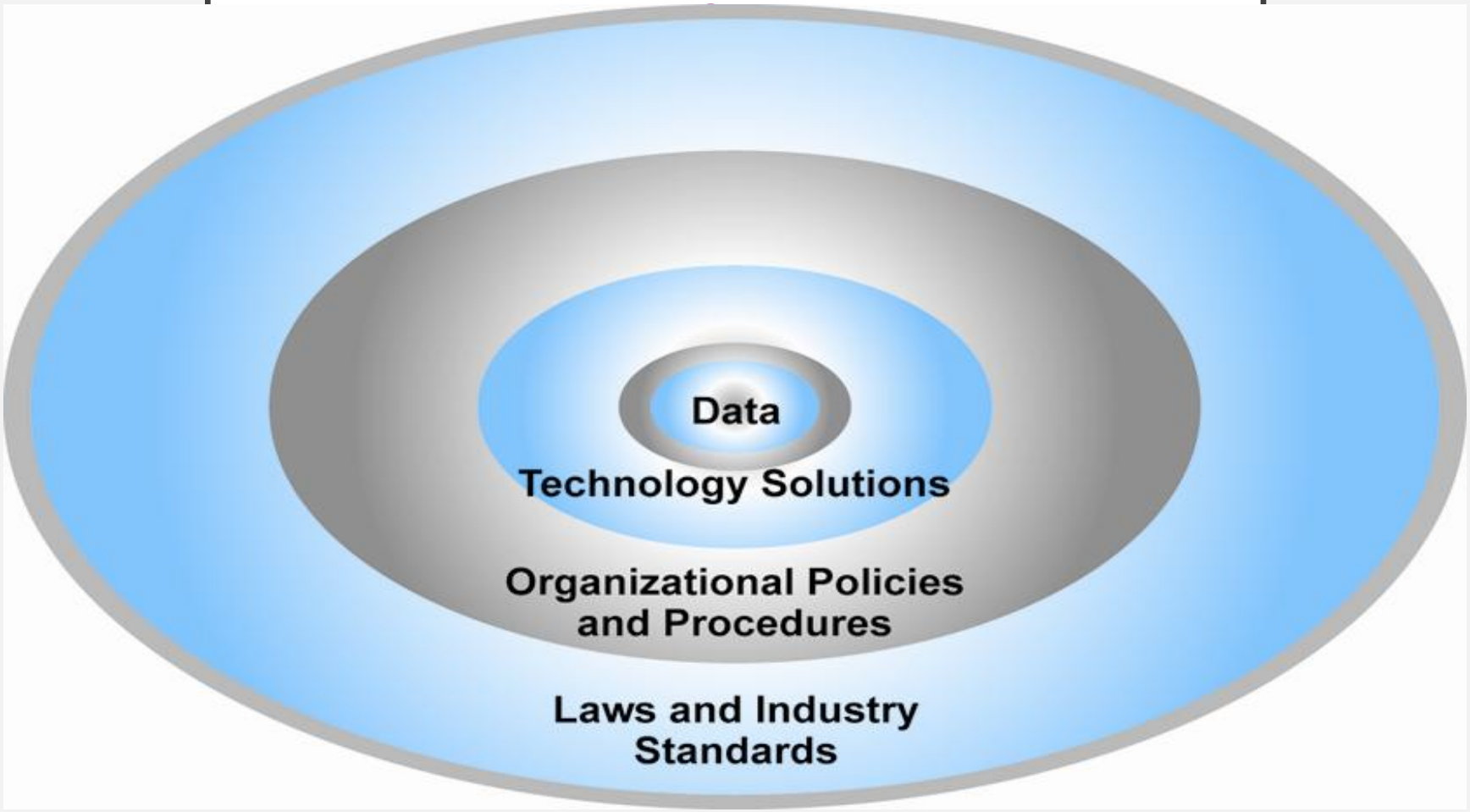
  → ubiquitous connectivity
- **Web server & its hardware**

  → complex systems and networks

WHAT IS GOOD E-COMMERCE SECURITY?

- To achieve highest degree of security
  - New technologies
  - Organizational policies and procedures
  - Industry standards and government laws
- Other factors
  - Time value of money
  - Cost of security vs. potential loss
  - Security often breaks at weakest link

THE E-COMMERCE SECURITY



DIFFERENT DIMESION ON THE E-C SECURITY

TABLE 5.3 CUSTOMER AND MERCHANT PERSPECTIVES ON THE DIFFERENT DIMENSIONS OF E-COMMERCE SECURITY

DIMENSION	CUSTOMER'S PERSPECTIVE	MERCHANT'S PERSPECTIVE
Integrity	Has information I transmitted or received been altered?	Has data on the site been altered without authorization? Is data being received from customers valid?
Nonrepudiation	Can a party to an action with me later deny taking the action?	Can a customer deny ordering products?
Authenticity	Who am I dealing with? How can I be assured that the person or entity is who they claim to be?	What is the real identity of the customer?
Confidentiality	Can someone other than the intended recipient read my messages?	Are messages or confidential data accessible to anyone other than those authorized to view them?
Privacy	Can I control the use of information about myself transmitted to an e-commerce merchant?	What use, if any, can be made of personal data collected as part of an e-commerce transaction? Is the personal information of customers being used in an unauthorized manner?
Availability	Can I get access to the site?	Is the site operational?

THE IMPORTANCE OF SECURING E-COMMERCE

The importance of securing e-commerce

i. **Secrecy:**
   - protection against unauthorized data disclosure and authentication of data source

ii. **Integrity:**
   - prevention against unauthorized data modification

iii. **Necessity**:
   - prevention against data delays or removal

iv. **Non-repudiation:**
   - prevention against any one party from reneging on an agreement after the fact

→ protect corporation's image and reputation

→ minimize the impact of security failures

→ minimize downtime

→ fulfill legal and regulatory requirements for data integrity/confidentiality and consumer privacy

E-COMMERCE THREATS

Threats:

- anyone with the capability, technology, opportunity, and intent to do harm.
  - Potential threats can be foreign or domestic, internal or external, state-sponsored or a single rogue element.
  - E.g. Terrorists, insiders, disgruntled employees, and hackers are included in this profile.

a) Intellectual property threats

- Use existing materials found on the Internet without the owner's permission, e.g., music downloading, domain name (cybersquatting), software pirating

b) Client computer threats

- Malicious codes
- Active contents

E-COMMERCE THREATS CONT….

3. Communication channel threats

- Sniffer program
- Backdoor
- Spoofing
- Denial-of-service

4. Server threats

- Privilege setting
- Server Side Include (SSI), Common Gateway Interface (CGI)
- File transfer
- Spamming

E-COMMERCE THREATS CONT….

- **How to identify threats?**
  - Vulnerability assessments or penetration tests
    - ***Risk = Threat x Vulnerability x Cost***
  - **Threat: frequency of potentially adverse event**

Threat	2002*	2001**	2000***
Viruses, Trojans, worms, hostile ActiveX and Java	31%	21%	26%
Loss of Privacy/confidentiality, data misuse/abuse	23%	28%	25%
System unavailability, denial of service, natural disasters, power outage	15%	18%	20%
Cracking, eavesdropping, spoofing	11%	25%	20%

E-COMMERCE THREATS CONT….

- ***Vulnerability:***
  - likelihood of success of a particular attack, e.g., Merchant Risk Council's fraud test
- **Cost:**
  - Real damages to hardware or software + IT staff time and resources spent repairing the damages + lost productivity, public relations damage control, lost public confidence, lost business opportunities, e.g., *Figure 15 of 2016 CSI/FBI Computer Crime & Security Survey*

THE INFORMATION SECURITY PROBLEM

- **The Status of Computer Security in the United States**
  - **CSI Computer Crime and Security Survey**

    Annual security survey of U.S. corporations, government agencies, financial and medical institutions, and universities conducted by the Computer Security Institute.

- Highlights from the survey:

- Most expensive computer security incidents were those involving financial fraud
- Virus incidents occurred frequently (50%) and insider abuse of networks second (44 %)
- One in every ten organizations experienced DNS incident
- 27% targeted attack were experienced . Targeted attack is a malware attack aimed exclusively at a particular organization.
- Vast majority of organizations had security policy only 1% did not have.

TYPES OF ATTACKS AGAINST COMPUTER SYSTEMS (CYBERCRIME)

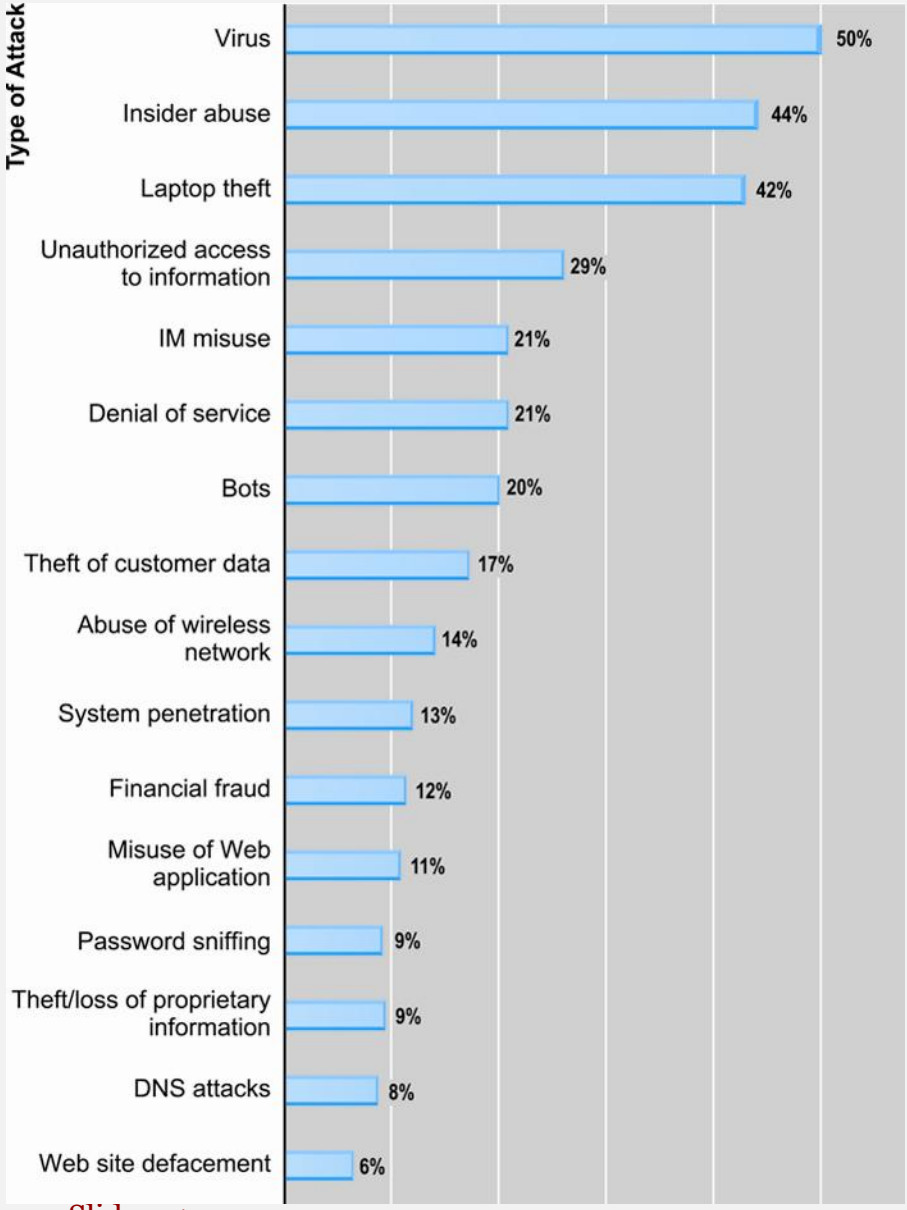


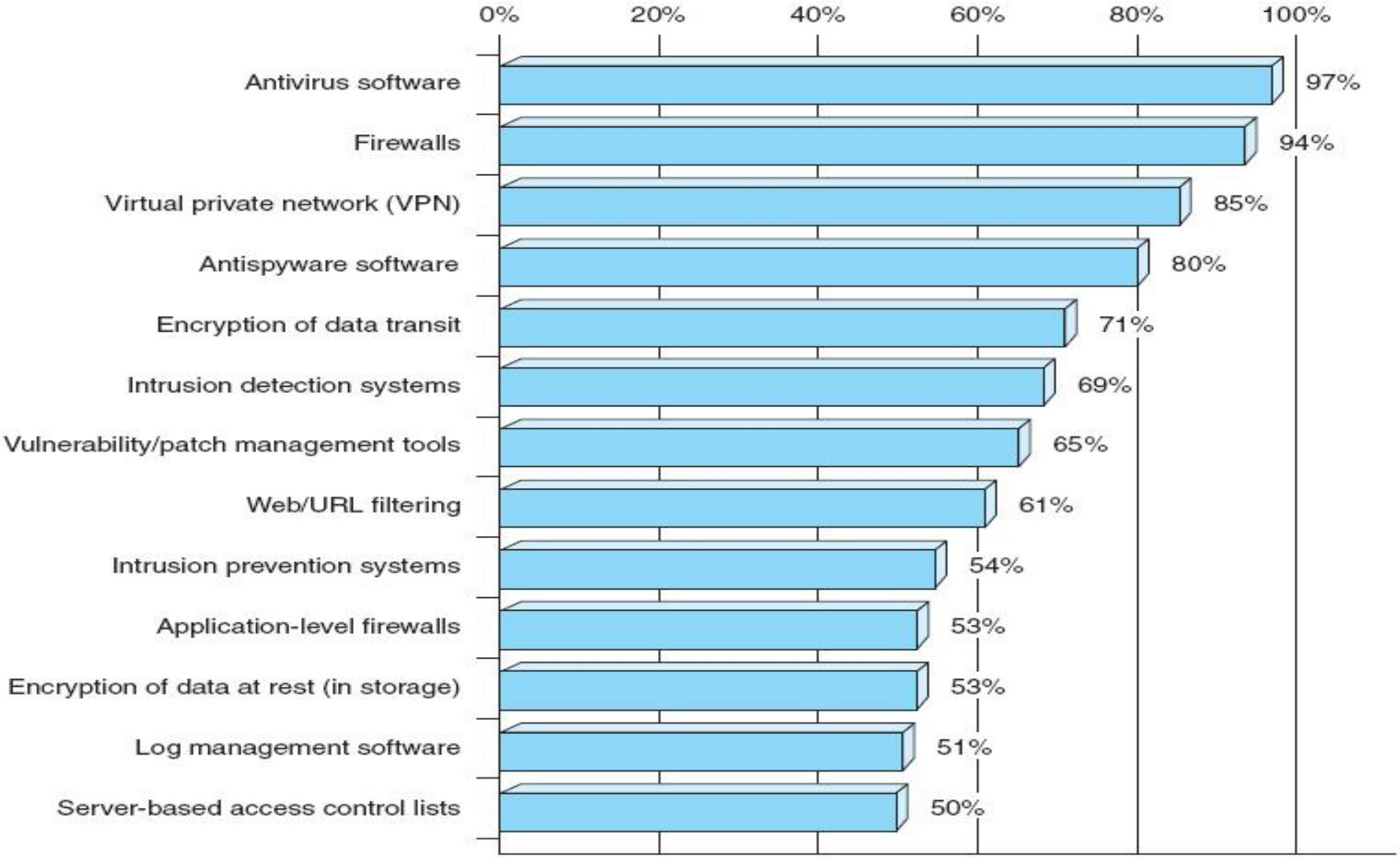
Figure 5.1, Page 267

Source: Based on data from Computer Security Institute,

TYPES OF ATTACKS AGAINST COMPUTER SYSTEMS (CYBERCRIME)

- **the 10 most common cyber attack types:**
  - Denial-of-service (DoS) and distributed denial-of-service (DDoS) **attacks**.
  - Man-**in**-the-middle (MitM) **attack**.
  - Phishing and spear phishing **attacks**.
  - Drive-by **attack**.
  - Password **attack**.
  - SQL injection **attack**.
  - Cross-site scripting (XSS) **attack**.
  - Eavesdropping **attack**.

EXHIBIT 9.2 Major Security Methods Used in 2008



THE E-COMMERCE SECURITY ENVIRONMENT

- Overall size and losses of cybercrime unclear
  - Reporting issues
- CSI survey: 49% of respondent firms detected security breach in previous year
  - Of those that shared numbers, average loss Ksh28,800,000
- Underground economy marketplace:
  - Stolen information stored on underground economy servers

THE INFORMATION SECURITY PROBLEM

- **THE DRIVERS OF EC SECURITY PROBLEMS**

A. The Internet's Vulnerable Design

- **domain name system (DNS)**

  Translates (converts) domain names to their numeric IP addresses.

- **IP address**

  An address that uniquely identifies each computer connected to a network or the Internet.

❑ Therefore lack of source authentication and data integrity checking in DNS operations leaves nearly all Internet services vulnerable to attacks

THE INFORMATION SECURITY PROBLEM: THE DRIVERS OF EC SECURITY PROBLEMS CONT….

B. The Shift to Profit-Induced Crimes

- Early days of e-commerce , many hackers simply wanted to gain fame or notoriety by defacing websites or gaining root (root access to a network)
- Todays criminals are profit-oriented

THE INFORMATION SECURITY PROBLEM: THE DRIVERS OF EC SECURITY PROBLEMS

C. Internet underground economy

- E-markets for stolen information made up of thousands of Web sites that sell credit card numbers, social security numbers, other data such as numbers of bank accounts, social network IDs, passwords, and much more.

- **keystroke logging (keylogging)**

  A method of capturing and recording user keystrokes. This method can be useful to law enforcers

D. The Dynamic Nature of EC Systems and the Role of Insiders

- EC systems are changing all the time and with it comes security problems.
- Many of security problems are caused by insiders and new insiders are being added frquently.

BASIC E-COMMERCE SECURITY ISSUES AND LANDSCAPE

- **THE SECURITY BASIC TERMINOLOGY**
  - **business continuity plan**
    - A plan that keeps the business running after a disaster occurs. Each function in the business should have a valid recovery capability plan.
  - **cybercrime**
    - Intentional crimes carried out on the Internet.
  - **exposure**
    - The estimated cost, loss, or damage that can result if a threat exploits a vulnerability.
  - **fraud**
    - Any business activity that uses deceitful practices or devices to deprive another of property or other rights.

THE TENSION BETWEEN SECURITY AND OTHER VALUES

- Ease of use:
  - The more security measures added, the more difficult a site is to use, and the slower it becomes
- Public safety and criminal uses of the Internet
  - Use of technology by criminals to plan crimes or threaten nation-state

WHY IS E-COMMERCE SECURITY STRATEGY NEEDED?

- The Computer Security Dilemma where security departments have big workloads, small budgets and are not able to optimize their EC security program for efficiency.
- Endless worms, spyware , data piracy keep them working reactively rather than strategically.
- Lack of a strategy makes their costs and efforts to be relatively high.
- Thus the need for a comprehensive security strategy.

BASIC E-COMMERCE SECURITY ISSUES AND LANDSCAPE

- **malware (malicious software)**

  A generic term for malicious software.

- **phishing**

  A crimeware technique to steal the identity of a target company to get the identities of its customers.

- **risk**

  The probability that a vulnerability will be known and used.

- **social engineering**

  A type of nontechnical attack that uses some user to trick users into revealing information or performing an action that compromises a computer or network.

BASIC E-COMMERCE SECURITY ISSUES AND LANDSCAPE

- **spam**

  The electronic equivalent of junk mail.

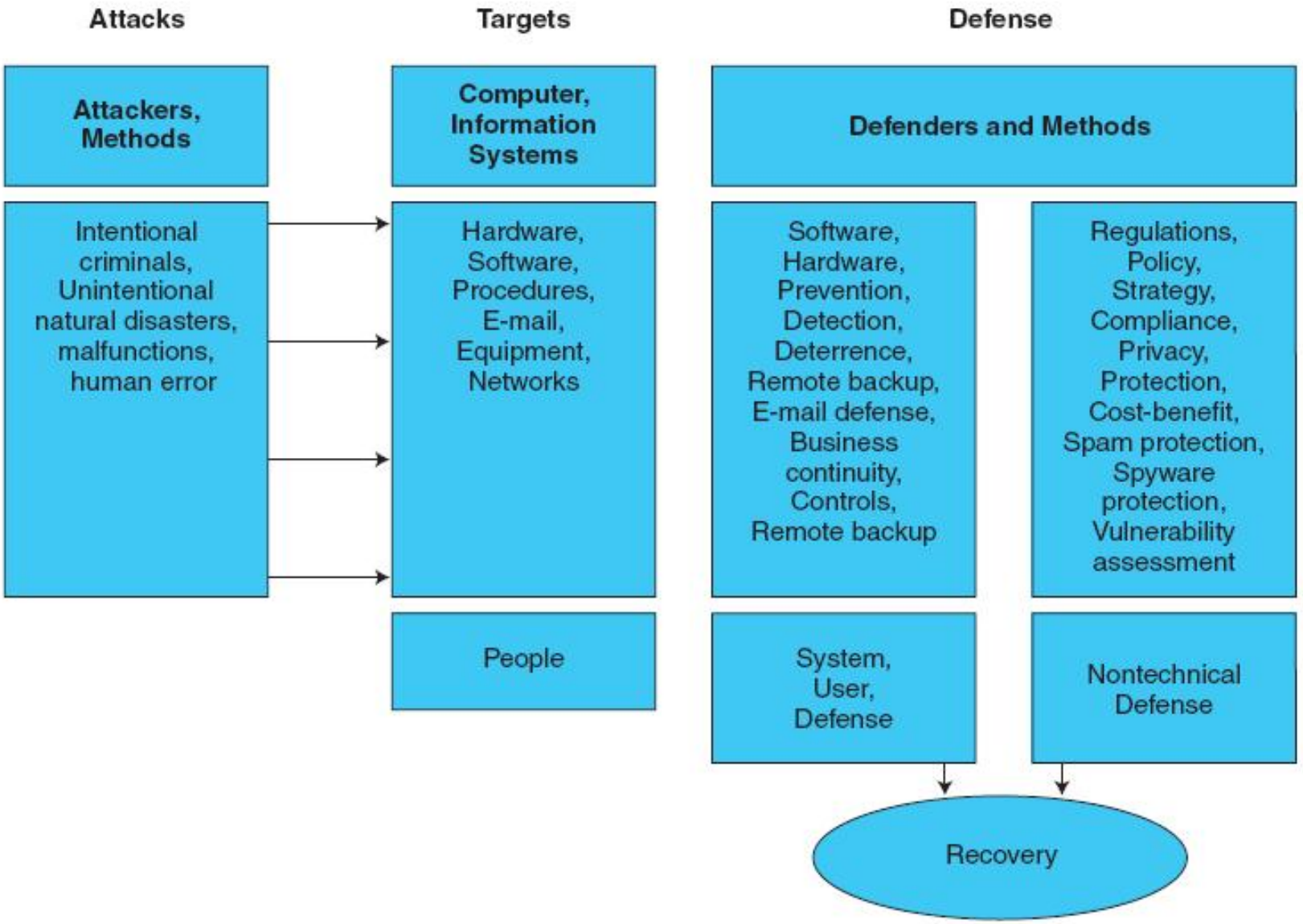
- **vulnerability**

  Weakness in software or other mechanism that threatens the confidentiality, integrity, or availability of an asset . It can be directly used by a hacker to gain access to a system or network.

- **zombies**

  Computers infected with malware that are under the control of a spammer, hacker, or other criminal.

EXHIBIT 9.3 The EC Security Battleground



BASIC E-COMMERCE SECURITY ISSUES AND LANDSCAPE

- **Threats and Attacks:**

1. **Unintentional and Intentional**

- Unintentional Threats
  - **Human error** can occur in the design of software or hardware, in programming, testing, data collection, data entry , negligence , misunderstanding etc.
  - **Environmental hazards** e.g. earthquakes , severe storm, power failure , fires etc.
  - Malfunctions in the computer system due to defects in the system as a result of poor manufacturing, defective material etc.

Intentional Attacks and Crimes

- they are done by criminals e.g. theft of data, inappropriate use of data etc.

BASIC E-COMMERCE SECURITY ISSUES AND LANDSCAPE: THREATS AND ATTACKS

2. Criminals and Social Engineering

- **cybercriminal**

  A person who intentionally carries out crimes over the Internet.

- **hacker**

  Someone who gains unauthorized access to a computer system.

- **cracker**

  A malicious hacker

BASIC E-COMMERCE SECURITY ISSUES AND LANDSCAPE

- **Vulnerable Areas Are Being Attacked**
  - Can be any part of an information system e.g. e-mails, data etc.

BASIC E-COMMERCE SECURITY ISSUES AND LANDSCAPE

- **EC Security Requirements-** in order to protect EC transactions the following requirements are used.
  - **authentication**

    Process to verify (assure) the real identity of an individual, computer, computer program, or EC Web site.
  - **authorization**

    Process of determining what the authenticated entity is allowed to access and what operations it is allowed to perform.
  - Auditing-process of recording of what was accessed, when and by whom upon access
  - Availability
  - **nonrepudiation**

    Assurance that online customers or trading partners cannot falsely deny (repudiate) their purchase or transaction.

BASIC E-COMMERCE SECURITY ISSUES AND LANDSCAPE

- **THE DEFENSE: DEFENDERS AND THEIR STRATEGY**
  - **EC security strategy**

    - A strategy that views EC security as the process of preventing and detecting unauthorized use of the organization's brand, identity, Web site, e-mail, information, or other asset and attempts to defraud the organization, its customers, and employees.

BASIC E-COMMERCE SECURITY ISSUES AND LANDSCAPE

- **EC security strategy includes:**
  - **deterring measures**

    Actions that will make criminals abandon their idea of attacking a specific system (e.g., the possibility of losing a job for insiders).
  - **prevention measures**

    Ways to help stop unauthorized users (also known as "intruders") from accessing any part of the EC system e.g requiring a password
  - **detection measures**

    Ways to determine whether intruders attempted to break into the EC system, whether they were successful, and what they may have done.

BASIC E-COMMERCE SECURITY ISSUES AND LANDSCAPE

- The ultimate goal of EC security is **information assurance (IA)**
  - The protection of information systems against unauthorized access to or modification of information whether in storage, processing, or transit, and against the denial of service to authorized users, including those measures necessary to detect, document, and counter such threats.

TECHNICAL ATTACK METHODS

- **TECHNICAL AND NONTECHNICAL ATTACKS: AN OVERVIEW**
  - Software and systems knowledge are used to perpetrate *technical attacks* (computer virus)
  - *Nontechnical attacks* are those in which a perpetrator uses some form of deception or persuasion to trick people into revealing information or performing actions that can compromise the security of a network

TECHNICAL ATTACK METHODS

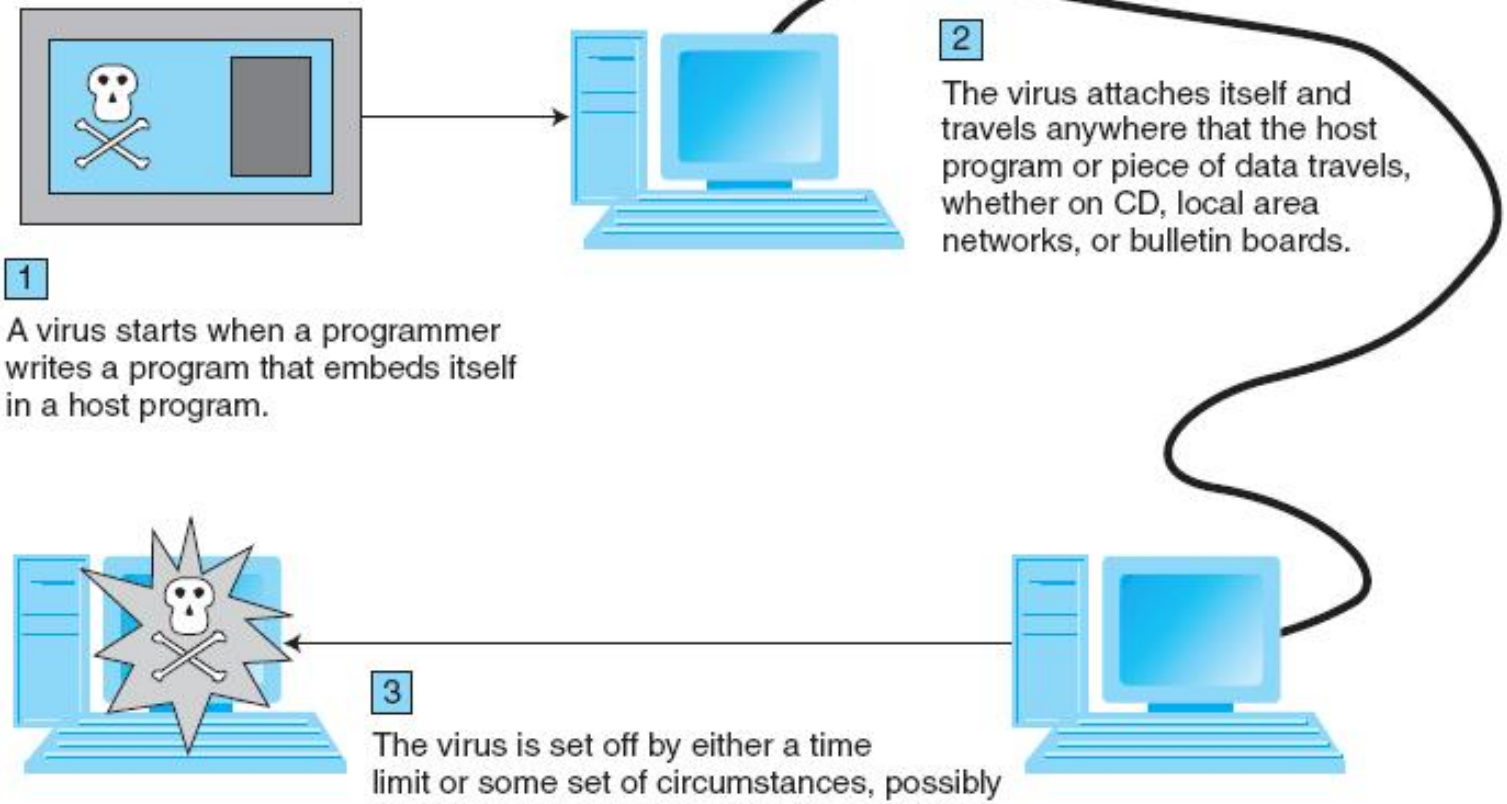
- **MALICIOUS CODE**
  - **virus**

    A piece of software code that inserts itself into a host, including the operating systems, in order to propagate; it requires that its host program be run to activate it.
  - **worm**

    A software program that runs independently, consuming the resources of its host in order to maintain itself, that is capable of propagating a complete working version of itself onto another machine.

EXHIBIT 9.4 How a Computer Virus Can Spread

Just as a biological virus disrupts living cells to cause disease, a computer virus—introduced maliciously—invades the inner workings of computers and disrupts normal operations of the machines.



1 A virus starts when a programmer writes a program that embeds itself in a host program.

2 The virus attaches itself and travels anywhere that the host program or piece of data travels, whether on CD, local area networks, or bulletin boards.

3 The virus is set off by either a time limit or some set of circumstances, possibly a simple sequence of computer operations by the user (e.g., open an attachment). Then it does whatever the virus programmer intended, whether it is to print "Have a nice day" or erase data.

TECHNICAL ATTACK METHODS

1. **macro virus (macro worm)**

   A macro virus or macro worm is executed when the application object that contains the macro is opened or a particular procedure is executed.

2. **Trojan horse**

   A program that appears to have a useful function but that contains a hidden function that presents a security risk.

3. **banking Trojan**

   A Trojan that comes to life when computer owners visit one of a number of online banking or e-commerce sites.

TECHNICAL ATTACK METHODS

4. denial of service (DoS) attack

An attack on a Web site in which an attacker uses specialized software to send a flood of data packets to the target computer with the aim of overloading its resources.

5. Web Server and Web Page Hijacking

- Web servers and web pages can be hijacked and configured to control or redirect unsuspecting users to scam or phishing sites. This method is used by cybercriminals and terrorist.

6. Botnet- an infected computer that forwards traffic.

A huge number (e.g., hundreds of thousands) of hijacked Internet computers that have been set up to forward traffic, including spam and viruses, to other computers on the Internet.

EXHIBIT 9.5 From Phishing to Financial Fraud and Crime

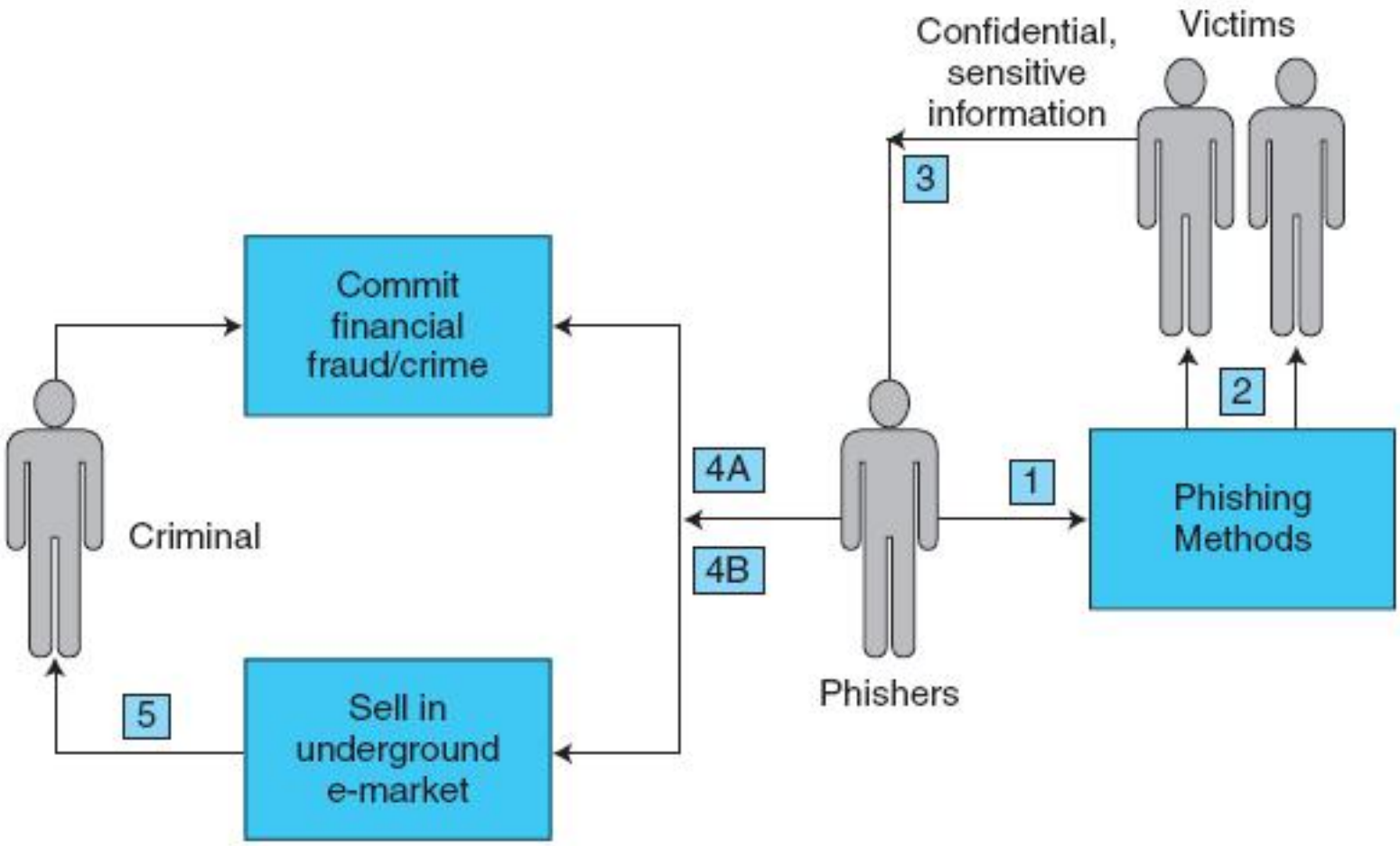
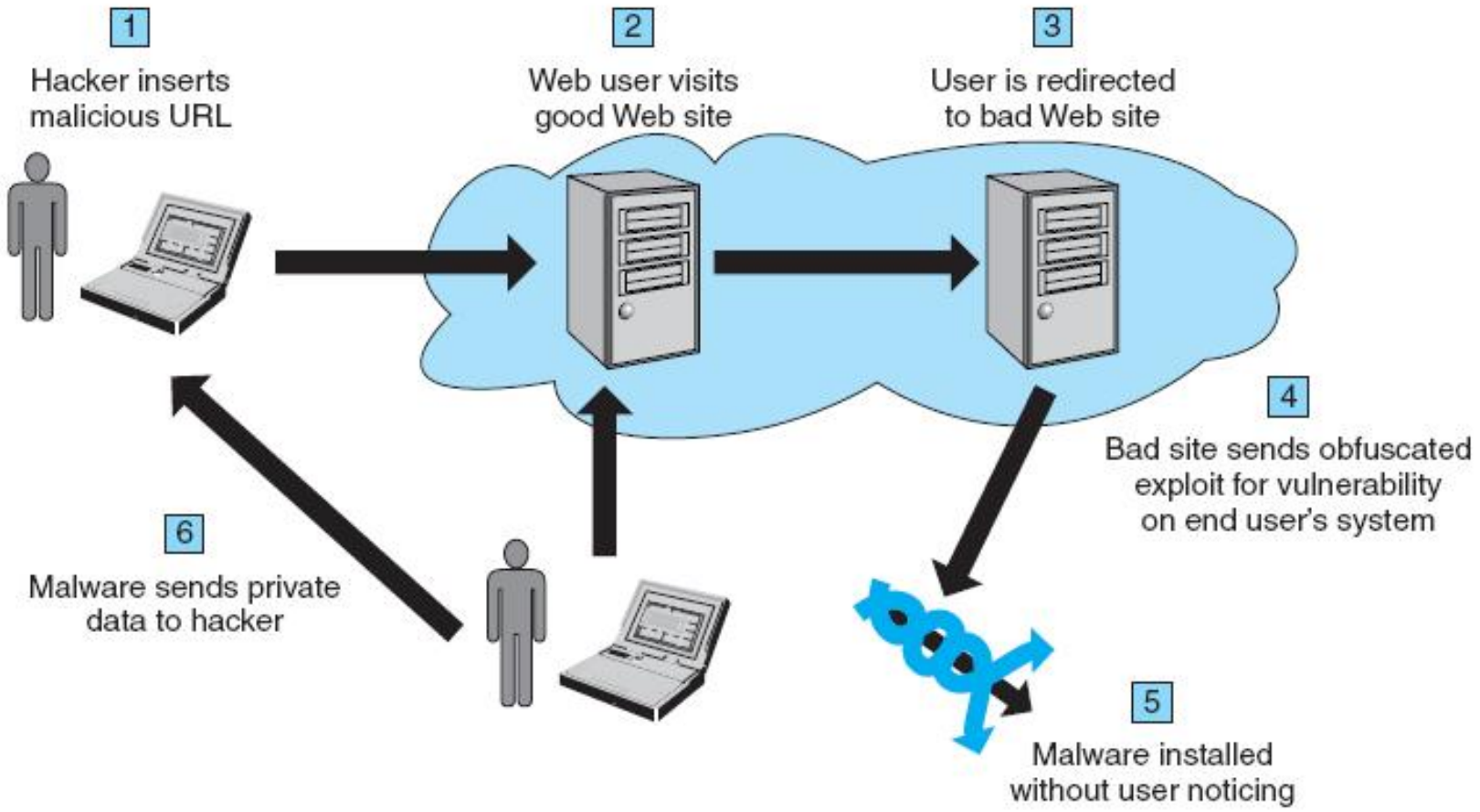


Fig: How cyber crimes are conducted.

EXHIBIT 9.6 How Phishing Is Accomplished



Obfuscate-render obsecure

PHISHING, FINANCIAL FRAUD, AND SPAM

- Phishing
  - is a fraudulent process of acquiring confidential information by masquerading as trustworthy entity
- **FRAUD ON THE INTERNET**
  - **Examples of Typical Online Fraud Attempts**
  - **identity theft**

    Fraud that involves stealing an identity of a person and then the use of that identity by someone pretending to be someone else in order to steal money or get other benefits.

PHISHING, FINANCIAL FRAUD, AND SPAM

- **Other Financial Fraud**
  - **SPAM AND SPYWARE ATTACKS**
    - **e-mail spam (junk e-mail)**

      A subset of spam that involves nearly identical messages sent to numerous recipients by e-mail.
    - **spyware**

      Software that gathers user information over an Internet connection without the user's knowledge.

PHISHING, FINANCIAL FRAUD, AND SPAM

- **search engine spam**

  Pages created deliberately to trick the search engine into offering inappropriate, redundant, or poor-quality search results.

- **spam site**

  Page that uses techniques that deliberately subvert a search engine's algorithms to artificially inflate the page's rankings.

- **splog**

  Short for *spam blog*. A site created solely for marketing purposes.

THE INFORMATION ASSURANCE MODEL AND DEFENSE STRATEGY

- **CIA security triad (CIA triad)**

  Three security concepts important to information on the Internet: confidentiality, integrity, and availability.

EXHIBIT 9.7 CIA Security Triad



THE INFORMATION ASSURANCE MODEL AND DEFENSE STRATEGY

- **confidentiality**

  Assurance of data privacy and accuracy. Keeping private or sensitive information from being disclosed to unauthorized individuals, entities, or processes.

- **integrity**

  Assurance that stored data has not been modified without authorization; a message that was sent is the same message as that which was received.

- **availability**

  Assurance that access to data, the Web site, or other EC data service is timely, available, reliable, and restricted to authorized users.

EXHIBIT 9.8 E-Commerce Security Framework

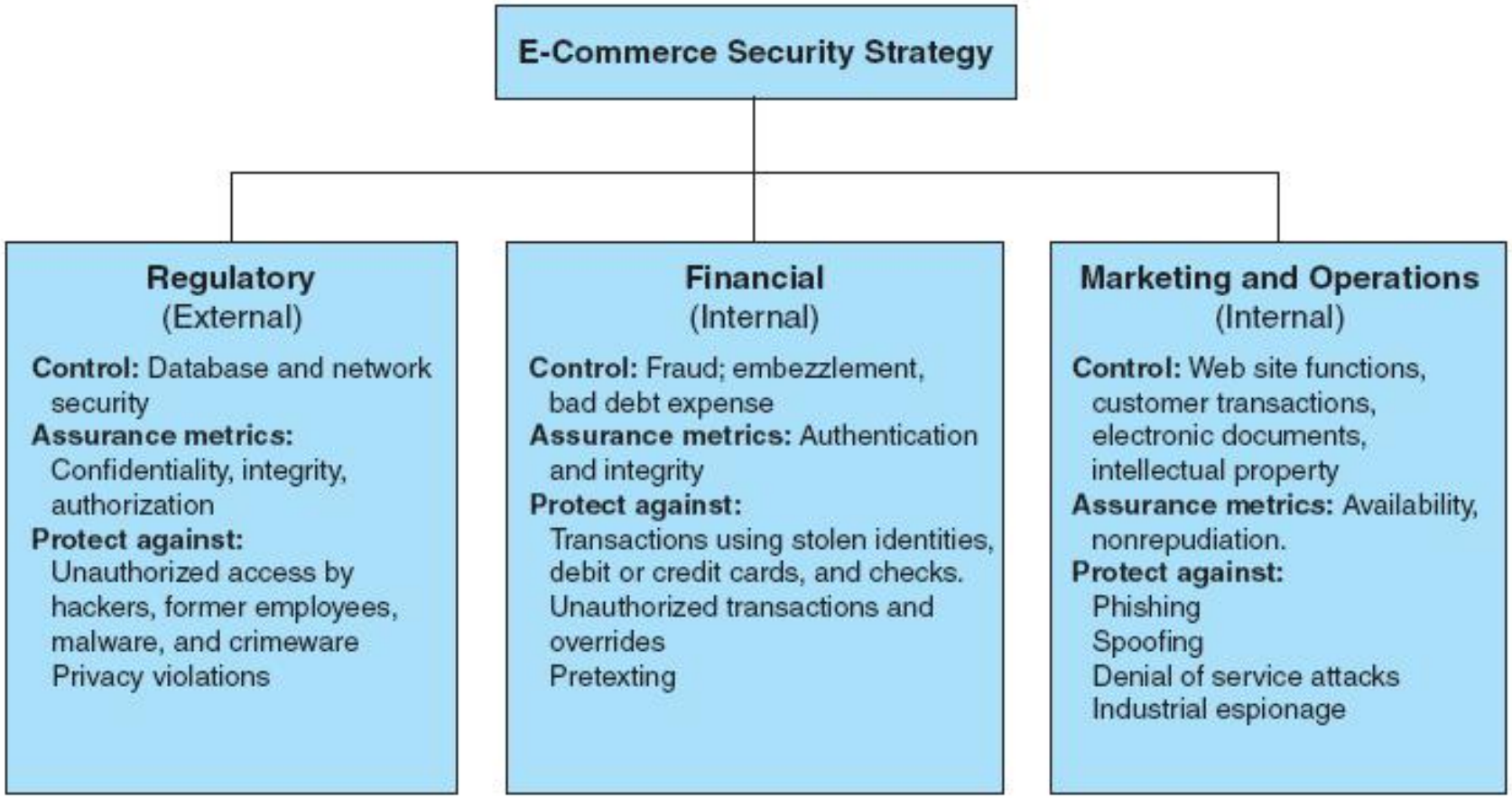


Fig: High level of categories of assurance and their controls

THE INFORMATION ASSURANCE MODEL AND DEFENSE STRATEGY

- **E-COMMERCE SECURITY STRATEGY Objectives:**
  1. Prevention and deterrence
  2. Detection
  3. Containment (contain the damage)
  4. Recovery
  5. Correction
  6. Awareness and compliance

- **EC security programs**

✓ is a set of controls over security processes to protect organizations assets

Four high-level stages:

I. Planning and organizing

II. Implementation

III. Operations and maintenance

IV. Monitoring and evaluating.

THE DEFENSE I: ACCESS CONTROL, ENCRYPTION, AND PKI

- **access control**

  Mechanism that determines who can legitimately use a network resource.

  - **Authentication and Passwords**
  - **biometric control**

    An automated method for verifying the identity of a person based on physical or behavioral characteristics.
  - **biometric systems**

    Authentication systems that identify a person by measurement of a biological characteristic, such as fingerprints, iris (eye) patterns, facial features, or voice.

THE DEFENSE I: ACCESS CONTROL, ENCRYPTION, AND PKI

- **ENCRYPTION AND THE ONE-KEY (SYMMETRIC) SYSTEM**
  - **encryption**

    The process of scrambling (encrypting) a message in such a way that it is difficult, expensive, or time-consuming for an unauthorized person to unscramble (decrypt) it.

  Basic parts of encryption

  - **plaintext**

    An unencrypted message in human-readable form.

  - **ciphertext**

    A plaintext message after it has been encrypted into a machine-readable form.

  - **encryption algorithm**

    The mathematical formula or procedures used to encrypt the plaintext into the ciphertext, and vice versa.

THE DEFENSE I: ACCESS CONTROL, ENCRYPTION, AND PKI

- **Terminologies**
  - **key (key value)**

    The secret code used to encrypt and decrypt a message.
  - **key space**

    The large number of possible key values (keys) created by the algorithm to use when transforming the message.
  - **symmetric (private) key encryption**

    An encryption system that uses the same key to encrypt and decrypt the message.
  - **Data Encryption Standard (DES)**

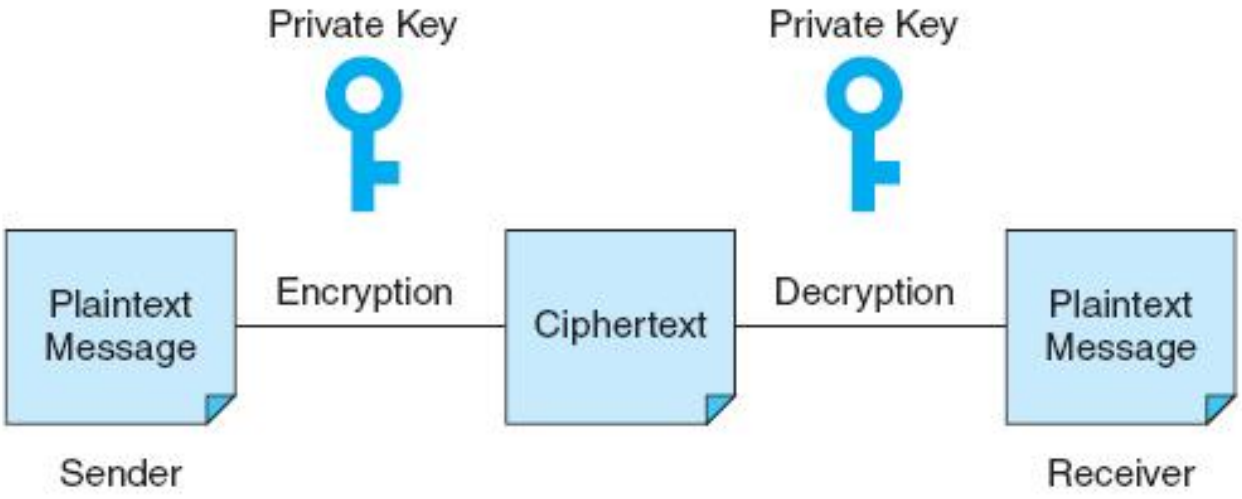
    The standard symmetric encryption algorithm supported by the NIST (National Institute of Standards and Technology) and used by U.S. government agencies until October 2000.

THE DEFENSE I: ACCESS CONTROL, ENCRYPTION, AND PKI

- **public key infrastructure (PKI)**

  A scheme for securing e-payments using public key encryption and various technical components.

EXHIBIT 9.10 Symmetric (Private) Key Encryption



Symmetrical algorithms are significantly faster than asymmetrical

THE DEFENSE I: ACCESS CONTROL, ENCRYPTION, AND PKI

- **public (asymmetric) key encryption**

  Method of encryption that uses a pair of matched keys—a public key to encrypt a message and a private key to decrypt it, or vice versa.

  - **public key**

    Encryption code that is publicly available to anyone.

  - **private key**

    Encryption code that is known only to its owner.

THE DEFENSE I: ACCESS CONTROL, ENCRYPTION, AND PKI

- **The PKI (public key infrastructure) Process**
  - **digital signature or digital certificate (equivalent of personal signatures)**
  - Is based on public keys for authenticating the identity of the sender of a message or a document
  - Ensures that the original content of electronic document or message is unchanged

    -Validates the sender and time stamp of a transaction so it cannot be later claimed that the transaction was unauthorized or invalid.

THE DEFENSE I

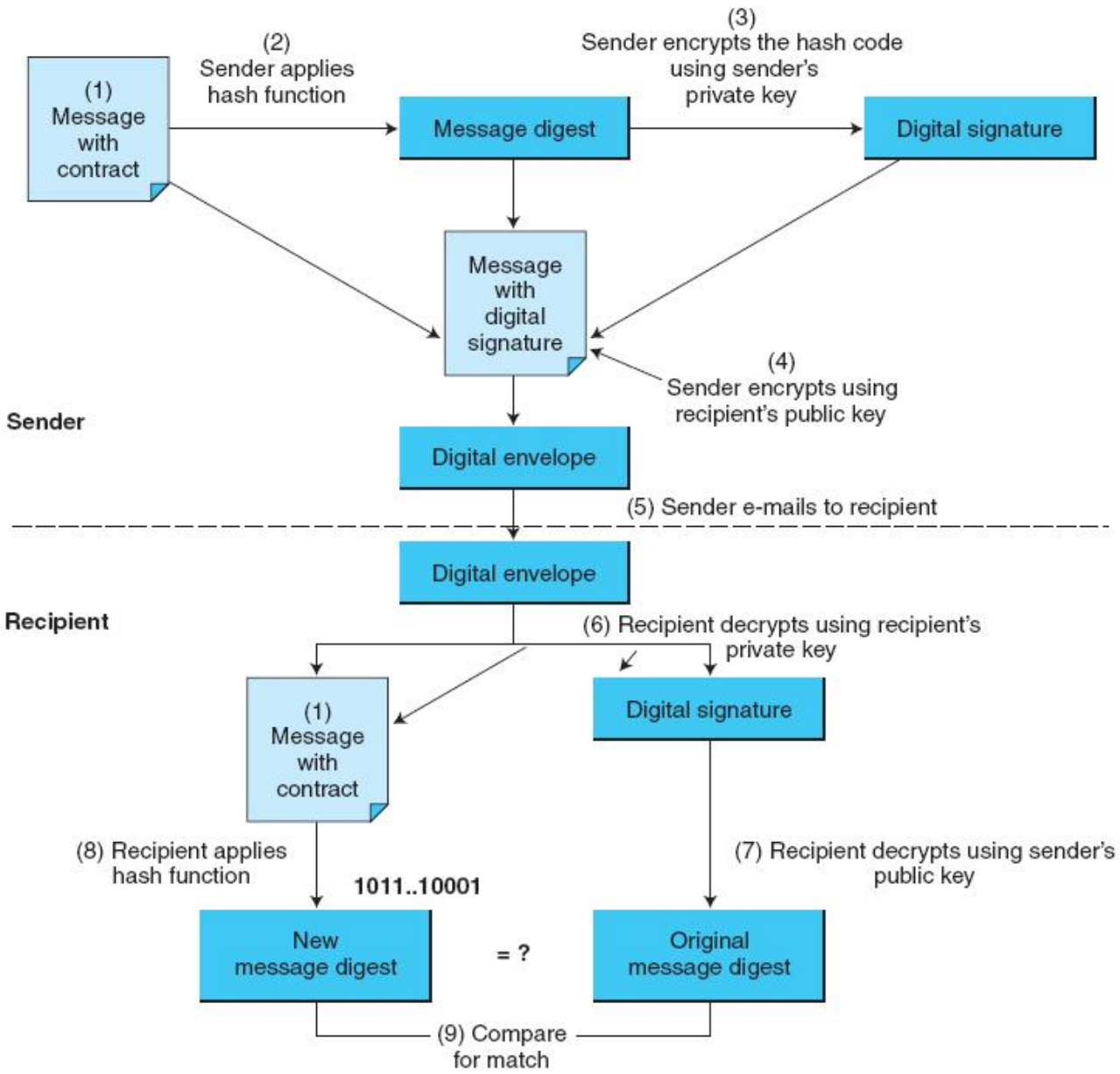
- **The PKI (public key infrastructure) Process**
  - **hash**

    A mathematical computation that is applied to a message, using a private key, to encrypt the message.
  - **message digest (MD)**

    A summary of a message, converted into a string of digits after the hash has been applied.
  - **digital envelope**

    The combination of the encrypted original message and the digital signature, using the recipient's public key.

EXHIBIT 9.11 Digital Signatures



THE DEFENSE I: ACCESS CONTROL, ENCRYPTION, AND PKI

- **certificate authorities (CAs)**

  Third parties that issue digital certificates e.g. VeriSign (verisign.com)

- information content of the certificate includes:

  the holders name, validity period, public key information, signed hash of the certificate

-Types of certificate

- site (website) certificates, individual (personal certificates and software companies (software publisher certificates.

THE DEFENSE I: ACCESS CONTROL, ENCRYPTION, AND PKI

- **Secure Socket Layer (SSL)**

  Protocol that utilizes standard certificates for authentication and data encryption to ensure privacy or confidentiality.

- **Transport Layer Security (TLS)**

  As of 1996, another name for the SSL protocol and was renamed TLS

-SSL is generally accepted protocol for e-commerce

THE DEFENSE II: SECURING E-COMMERCE NETWORKS

- **firewall**

  A single point between two or more networks where all traffic must pass (choke point); the device authenticates, controls, and logs all traffic.

  - **packet**

    Segment of data sent from one computer to another on a network.

  - **personal firewall**

    A network node designed to protect an individual user's desktop system from the public network by monitoring all the traffic that passes through the computer's network interface card. For details refer to firewallguide.com/software.html

THE DEFENSE II: SECURING E-COMMERCE NETWORKS

- **virtual private network (VPN)**

  A network that uses the public Internet to carry information but remains private by using **encryption to scramble the communications**, authentication **to ensure that information has not been tampered with**, and access control **to verify the identity of anyone using the network.**

  - **protocol tunneling**

    Method used to ensure confidentiality and integrity of data transmitted over the Internet by encrypting data packets, sending them in packets across the Internet, and decrypting them at the destination address.

THE DEFENSE II: SECURING E-COMMERCE NETWORKS

- **intrusion detection system (IDS)**

  A special category of software that can monitor activity across a network or on a host computer, watch for suspicious activity, and take automated action based on what it sees.
- IDS check flies on regular basis to see if the current signatures match the previous .
- Network based IDSs uses rules to analyze suspicious activity at the perimeter of the network or key locations in the network.
- Network-based IDS consists of a monitor (a software package that scans the network and software agent that resides on host computers and feeds information back to the monitor.

THE DEFENSE II: SECURING E-COMMERCE NETWORKS

- **honeynet**

  A network of honeypots which detect and analyze intrusions

- **honeypot**

  Production system or information system resources (e.g., firewalls, routers, Web servers, database servers) that looks like it does real work, but that acts as a decoy and is watched to study how network intrusions occur.

- **penetration test (pen test)**

  A method of evaluating the security of a computer system or a network by simulating an attack from a malicious source, (e.g., a cracker).

THE DEFENSE III: GENERAL CONTROLS AND OTHER DEFENSE MECHANISMS

- **general controls**

  Controls established to protect the system regardless of the specific application. For example, protecting hardware and controlling access to the data center are independent of the specific application. They include physical controls and Administrative controls

- **application controls**

  Controls that are intended to protect specific applications.

THE DEFENSE III: GENERAL CONTROLS AND OTHER DEFENSE MECHANISMS

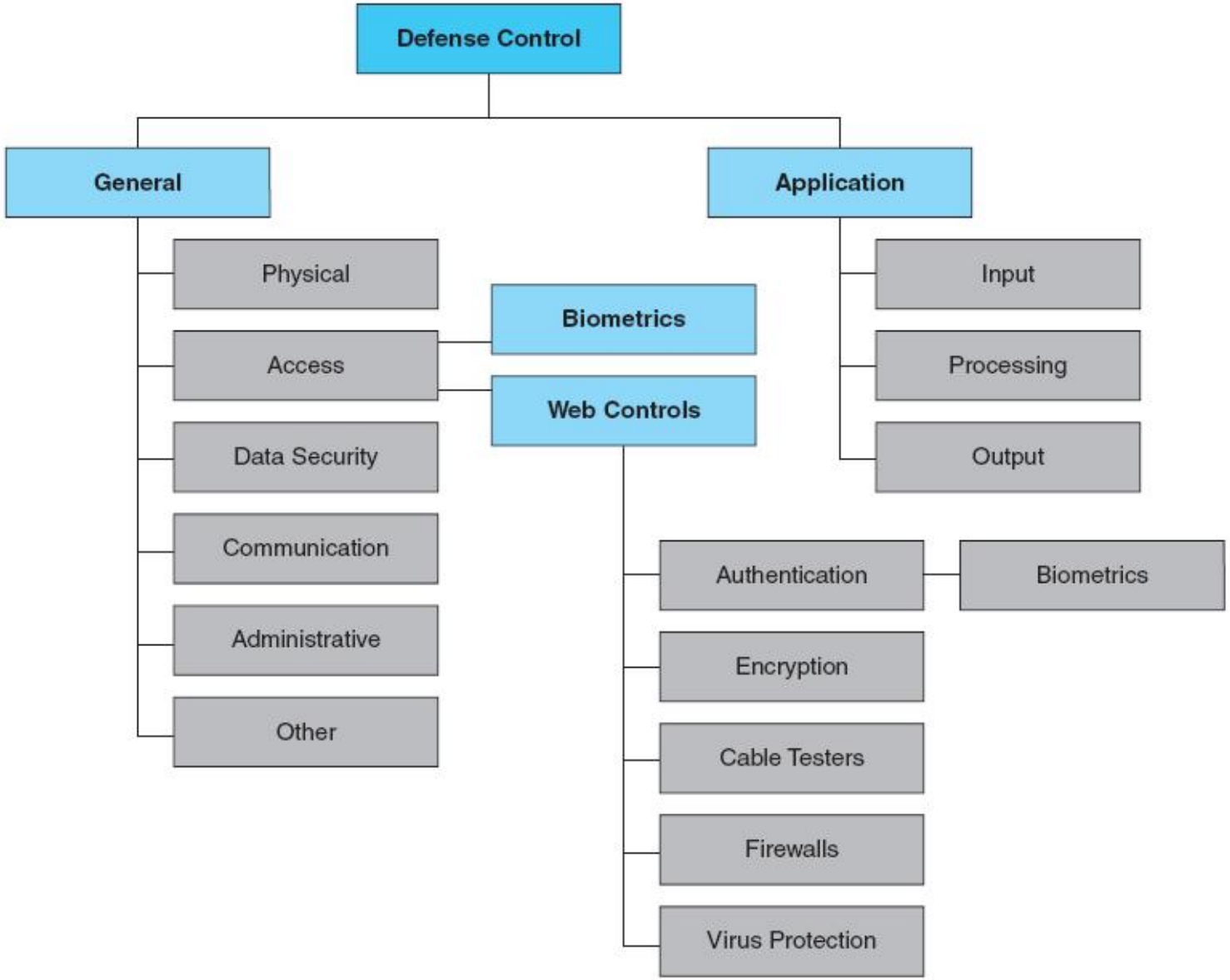
- Physical controls refers to protection of computer facilities and resources e.g. data centers, computers, software, manuals and networks
- Administrative controls deals with issuing guidelines and monitoring compliance with the same.

THE DEFENSE III: GENERAL CONTROLS AND OTHER DEFENSE MECHANISMS

Application controls

- Sophisticated attacks are aimed at application level and many applications are not designed to withstand such attacks
- Survivability of information processing is achieved by making use of **agent technology**
- **Intelligent agents** are also referred to as softbots or knowbots which have some degree of autonomy and adaptability.
- The softbots are required in unpredictable attack situations

EXHIBIT 9.12 Major Defense Controls



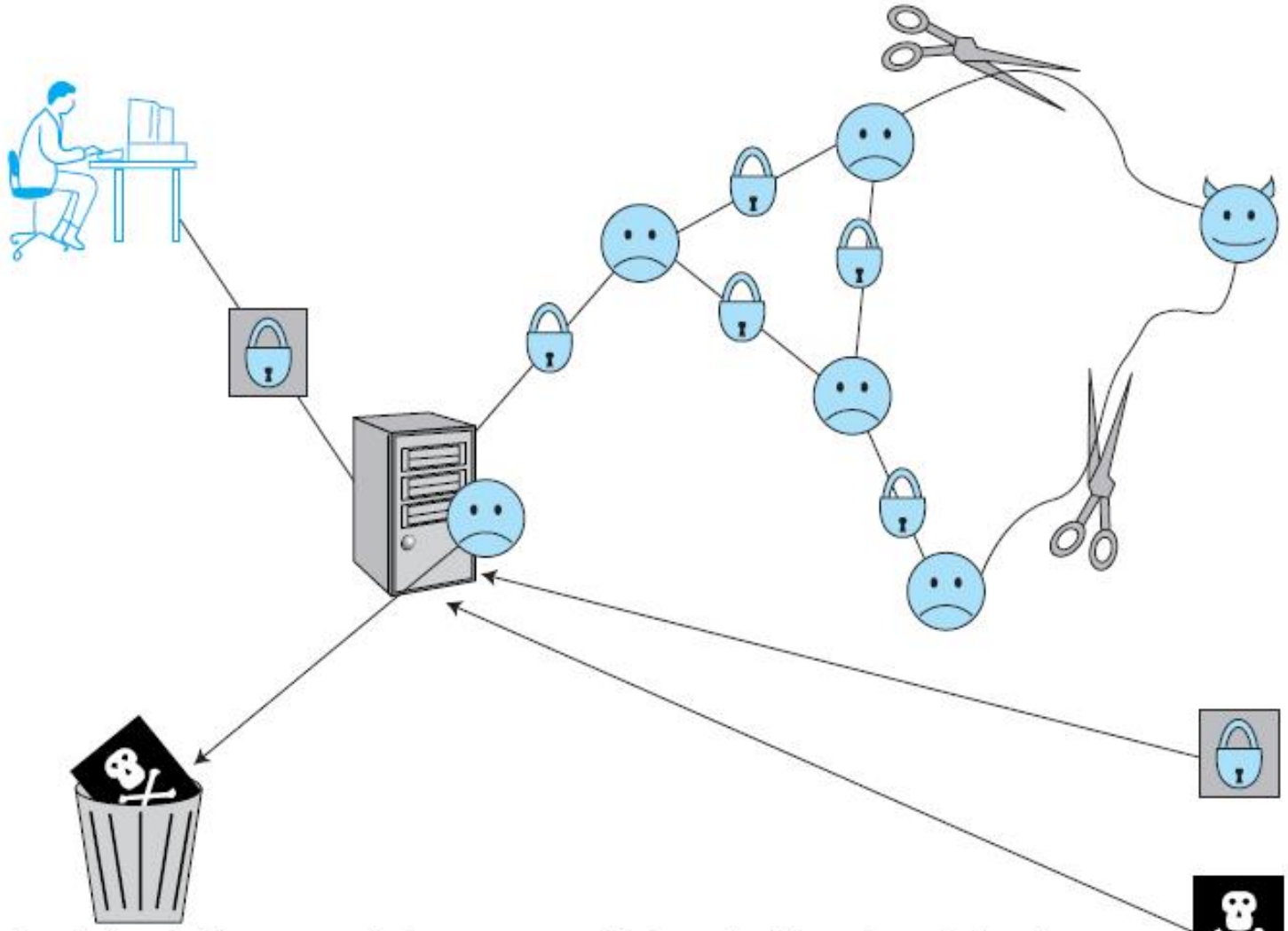
THE DEFENSE III: GENERAL CONTROLS AND OTHER DEFENSE MECHANISMS

- **APPLICATION CONTROLS**
  - **intelligent agents**

    Software applications that have some degree of reactivity, autonomy, and adaptability—as is needed in unpredictable attack situations. An agent is able to adapt itself based on changes occurring in its environment.
  - **internal control environment**

    The work atmosphere that a company sets for its employees.

EXHIBIT 9.14 Intelligent Agents



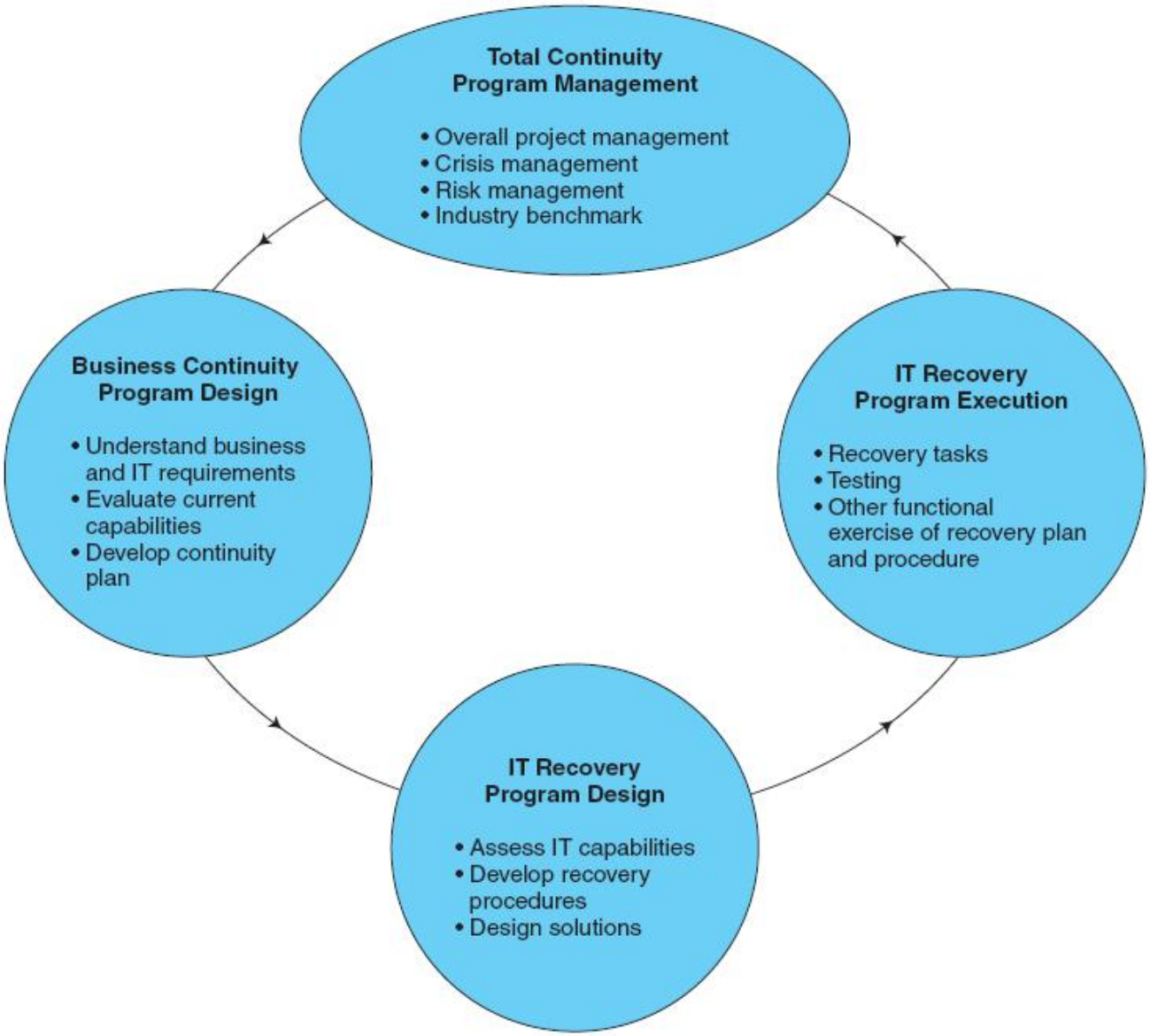
Agents in collective communicate over secured links on the Internet or an intranet. Malicious agents (with horns) are detected and cut off from the collective. Property authenticated data is allowed into the collective, but bad information is rejected.

THE DEFENSE III: GENERAL CONTROLS AND OTHER DEFENSE MECHANISMS

- **PROTECTING AGAINST SPAM**
  - **Controlling the Assault of Non-Solicited Pornography and Marketing (CAN-SPAM) Act**

    Law that makes it a crime to send commercial e-mail messages with false or misleading message headers or misleading subject lines.
- **PROTECTING AGAINST POP-UP ADS**
- **PROTECTION AGAINST PHISHING**
- **PROTECTING AGAINST SPYWARE**

EXHIBIT 9.15 Business Continuity Services



BUSINESS CONTINUITY, SECURITY AUDITING, AND RISK MANAGEMENT

- **BUSINESS CONTINUITY AND DISASTER RECOVERY PLANNING**
  - **disaster avoidance**

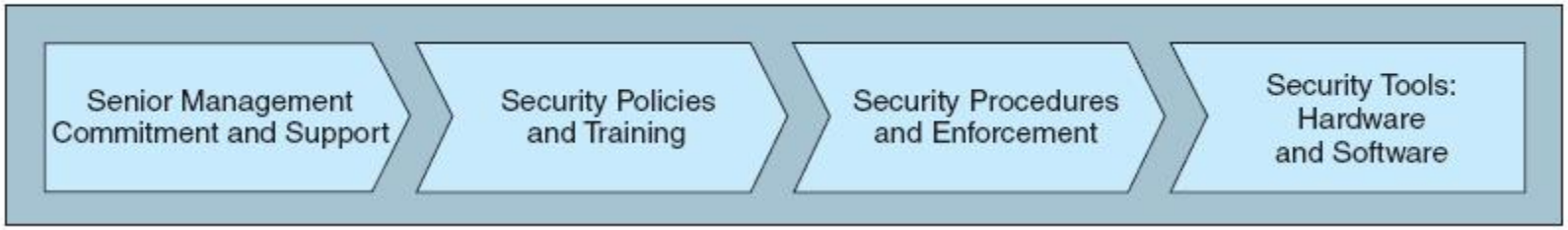
    An approach oriented toward prevention. The idea is to minimize the chance of avoidable disasters (such as fire or other human-caused threats).
- **RISK-MANAGEMENT AND COST-BENEFIT ANALYSIS**
  - **Risk-Management Analysis**
  - **Ethical Issues**

IMPLEMENTING ENTERPRISE-WIDE E-COMMERCE SECURITY

- **SENIOR MANAGEMENT COMMITMENT AND SUPPORT**
- **EC SECURITY POLICIES AND TRAINING**
  - **acceptable use policy (AUP)**

    Policy that informs users of their responsibilities when using company networks, wireless devices, customer data, and so forth.

EXHIBIT 9.16 **Enterprise-wide EC Security and Privacy Model**



Success of EC security strategy depends on.. above

IMPLEMENTING ENTERPRISE-WIDE E-COMMERCE SECURITY

- **EC SECURITY PROCEDURES AND ENFORCEMENT**
  - **business impact analysis (BIA)**

    An exercise that determines the impact of losing the support of an EC resource to an organization and establishes the escalation of that loss over time, identifies the minimum resources needed to recover, and prioritizes the recovery of processes and supporting systems.

IMPLEMENTING ENTERPRISE-WIDE E-COMMERCE SECURITY

- **WHY IS IT DIFFICULT TO STOP INTERNET CRIME?**
  - **Making Shopping Inconvenient- Strong EC security**
  - **Shoppers' Negligence-falling victim to identity theft etc**
  - **Ignoring EC Security Best Practices implementation by companies**
    - **Computing Technology Industry Association (CompTIA)**

      Nonprofit trade group providing information security research and best practices.
  - **Design and Architecture Issues – prevent problems early**
  - **standard of due care**
  - lack of due care in hiring practices , outsourcing and business partnerships

MANAGERIAL ISSUES

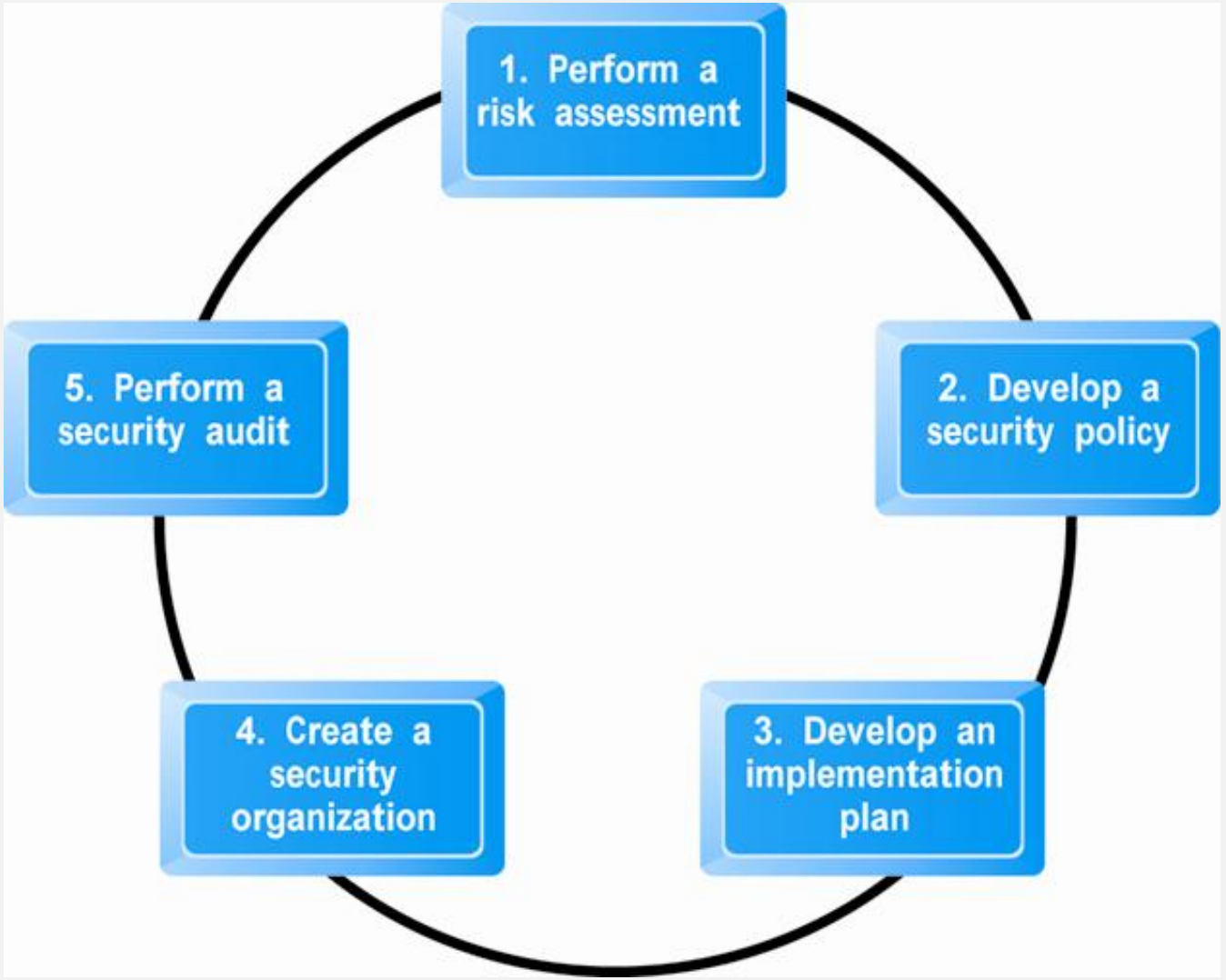
1. What is the EC security strategy of your company you were working for during attachment
2. Is the budget for IT security adequate?
3. What steps should businesses follow in establishing a security plan?
4. Should organizations be concerned with internal security threats?
5. What is the key to establishing strong

   e-commerce security?

A SECURITY PLAN: MANAGEMENT POLICIES

- Risk assessment
- Security policy
- Implementation plan
  - Security organization
  - Access controls
  - Authentication procedures, including biometrics
  - Authorization policies, authorization management systems
- Security audit

DEVELOPING AN E-COMMERCE SECURITY PLAN



THE ROLE OF LAWS AND PUBLIC POLICY

- Laws that give authorities tools for identifying, tracing, prosecuting cybercriminals:
  - National Information Infrastructure Protection Act of 1996
  - USA Patriot Act
  - Homeland Security Act
- Private and private-public cooperation
  - CERT Coordination Center
  - US-CERT
- Government policies and controls on encryption software
- OECD guidelines

TYPES OF PAYMENT SYSTEMS

- Cash
  - Most common form of payment
  - Instantly convertible into other forms of value
- Checking transfer
  - Second most common payment form in United States
- Credit card
  - Credit card associations
  - Issuing banks
  - Processing centers

TYPES OF PAYMENT SYSTEMS (CONT.)

- Stored value
  - Funds deposited into account, from which funds are paid out or withdrawn as needed, e.g., debit cards, gift certificates
  - Peer-to-peer payment systems
- Accumulating balance
  - Accounts that accumulate expenditures and to which consumers make period payments
  - e.g., utility, phone, American Express accounts

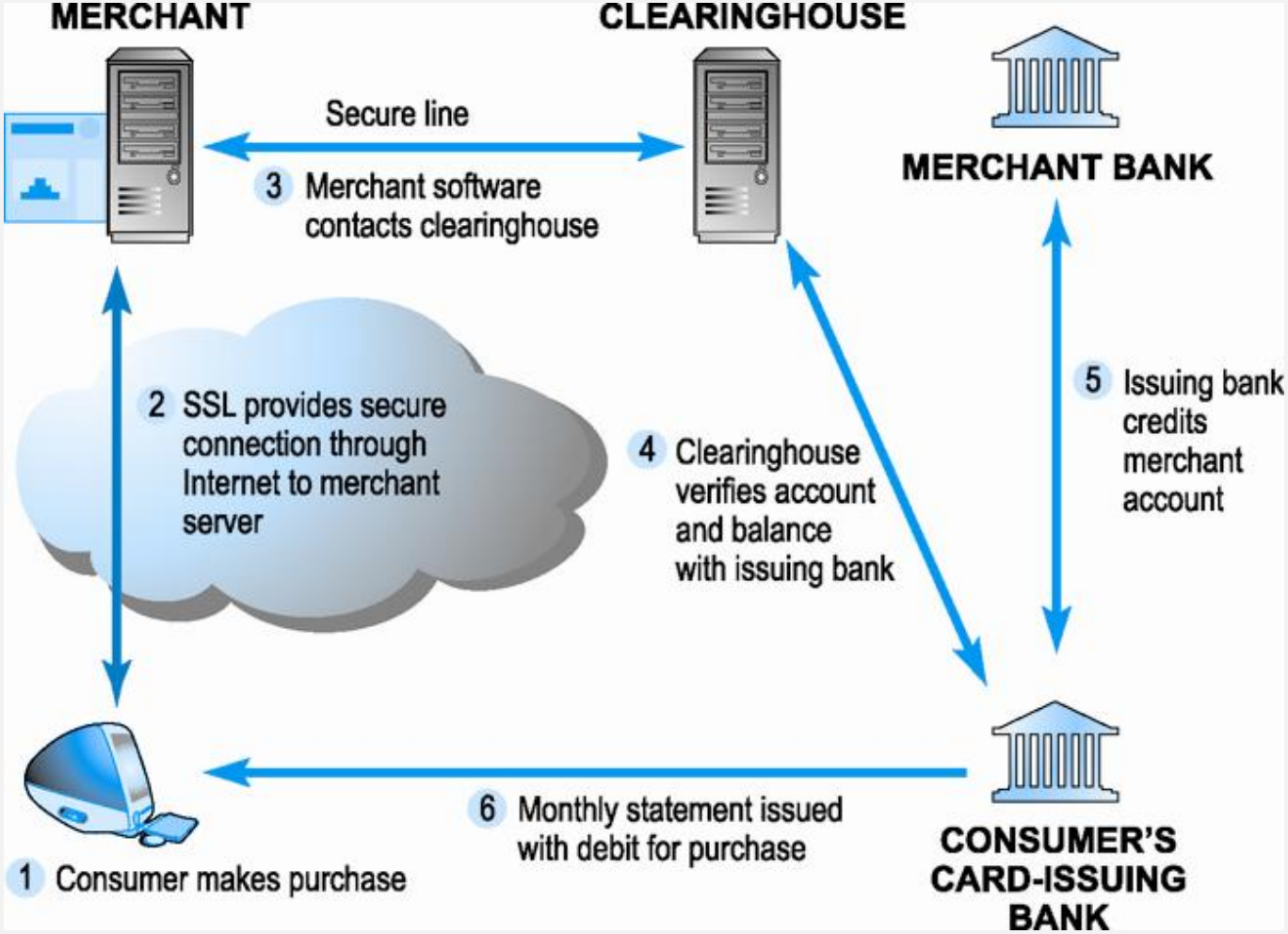
PAYMENT SYSTEM STAKEHOLDERS' PRIORITIES

- Consumers
  - Low-risk, low-cost, refutable, convenience, reliability
- Merchants
  - Low-risk, low-cost, irrefutable, secure, reliable
- Financial intermediaries
  - Secure, low-risk, maximizing profit
- Government regulators
  - Security, trust, protecting participants and enforcing reporting

E-COMMERCE PAYMENT SYSTEMS

- Credit cards
  - 45% of online payments in 2011 (U.S.)
- Debit cards
  - 28% online payments in 2011 (U.S.)
- Limitations of online credit card payment
  - Security, merchant risk
  - Cost
  - Social equity

HOW AN ONLINE CREDIT TRANSACTION WORKS



E-COMMERCE PAYMENT SYSTEMS (CONT.)

- Digital wallets
  - Emulates functionality of wallet by authenticating consumer, storing and transferring value, and securing payment process from consumer to merchant
  - Early efforts to popularize failed
  - Latest effort: Google Checkout
- Digital cash
  - Value storage and exchange using tokens
  - Most early examples have disappeared; protocols and practices too complex

E-COMMERCE PAYMENT SYSTEMS (CONT.)

- Online stored value systems
  - Based on value stored in a consumer's bank, checking, or credit card account
  - PayPal
  - Smart cards
    - Contact—use card reader
    - Contactless
      - e.g., EZPass, Octopus card (Hong Kong)
      - Radio Frequency ID (RFID)
      - Near Field Communications (NFC)

E-COMMERCE PAYMENT SYSTEMS (CONT.)

- Digital accumulated balance payment:
  - Users accumulate a debit balance for which they are billed at the end of the month
  - PaymentsPlus, BillMeLater
- Digital checking:
  - Extends functionality of existing checking accounts for use online
  - PayByCheck, EBillMe

MOBILE PAYMENT SYSTEMS

- Use of mobile handsets as payment devices well-established in Europe, Japan, South Korea
- Japanese mobile payment systems
  - E-money (stored value)
  - Mobile debit cards
  - Mobile credit cards
- Not as well established yet in United States
  - Infrastructure still developing
  - Apple, Google, RIM developing separate NFC systems

ELECTRONIC BILLING PRESENTMENT AND PAYMENT (EBPP)

- Online payment systems for monthly bills
- 30% + of households in 2010 used some EBPP; expected to continue to grow
- Two competing EBPP business models:
  - Biller-direct (dominant model)
  - Consolidator
- Both models are supported by EBPP infrastructure providers

THE END

- Q and Comments..